

SECURE DEPLOYMENT ENVIRONMENT

Hardening check linux sistema

Sistemi i korisnici.....	2
Informacije o OS i kernelu.....	2
NTP i vremenska zona.....	2
Korisnici i grupe (/etc/passwd).....	2
Algoritmi za heširanje šifri (/etc/shadow).....	3
Instalirani paketi.....	3
Mreža i firewall.....	4
Otvoreni portovi i servisi.....	4
Firewall pravila.....	4
Mrežni interfejsi.....	4
SSH konfiguracija.....	4
DNS konfiguracija.....	5
Fajl sistem i servisi.....	6
Setuid fajlovi.....	6
Fajlovi koje svi korisnici mogu da mijenjaju.....	6
Backup fajlovi sa lošim permisijama.....	6
Crontab zadaci i permisije skripti.....	6
Mounted particije.....	7

Sistemi i korisnici

Informacije o OS i kernelu

Prikazuje osnovne informacije o sistemu. Ovo uključuje ime operativnog sistema, njegovu verziju, verziju kernela i vreme proteklo od uključivanja sistema.

Bezbednosni problemi:

- Starije verzije operativnih sistema uglavnom nisu podržane. Ovo znači da neće biti ažurirane sa novim sigurnosnim ispravkama, što čini sistem osetljivim na pronađene napade za tu verziju.
- Na osnovu verzije kernela može se preciznije odrediti da li ta verzija ima poznate slabosti. Pomoću vremena proteklog od uključivanja sistema može se videti da li je davno gašen, što može biti dobar indikator da dugo nije dobio sigurnosnu ispravku.

NTP i vremenska zona

Proverava vremensku zonu sistema i da li je uključena sinhronizacija pomoću NTP servera. Obaveštava korisnika zavisno od stanja obe provere.

Bezbednosni problemi:

- Sistem ne treba da koristi vremensku zonu sa letnjim računanjem vremena. Tokom promene sata može doći do nekozistentnosti log-ova. Ovo može dovesti do preklapanja vremena ili do težeg povezivanje sa drugim izvorima log-ova.
- Sistem treba da ima uključenu vremensku sinhronizaciju pomoću NTP servera. Loša sinhronizacija vremena može dovesti do problema sa održavanjem log-ova, SSL verifikacijom sertifikata, autentifikacijom koja zavisi od vremena ...

Korisnici i grupe (/etc/passwd)

Proverava sadržaj */etc/passwd* datoteke. Proverava da li postoji *ne-root* korisnik sa UID 0. Takođe ispisuje listu korisnika sa pristupom shell-u.

Bezbednosni problemi:

- Ako korisnik ima UID 0, onda ima root pristup sistemu. Ovo može dovesti do loše konfiguracije sistema i mogućeg *backdoor*-a. Samo *root* i *toor* korisnici trebaju imati UID 0.
- Neki korisnici mogu imati pristup shell-u iako im nije potreban. Treba ograničiti pristup shell-u korisnicima kojima on nije potreban.

Algoritmi za heširanje šifri (/etc/shadow)

Proverava sadržaj */etc/shadow* datoteke radi provere algoritama korišćenih za enkripciju šifri. Proverava da li postoje korisnici bez šifre. Proverava da li neki korisnici koriste MD5 ili DES algoritme za enkripcije, koji mogu biti nesigurni.

Bezbednosni problemi:

- Korisnici bez šifre nemaju nikakvu zaštitu i može im se direktno pristupiti, što napadaču daje pristup sistemu.
- MD5 algoritam je zastareo i može se lako probiti brute-force tehnikama. Preporučuju se moderniji algoritmi za enkripciju.
- DES algoritam je takođe zastareo i može se lako *krekovati*. DES algoritmi takođe ograničavaju dužinu šifru na 8 karaktera, što je čini još lakšom za probijanje.

Napomena: Potreban je root pristup za čitanje */etc/shadow* datoteke.

Instalirani paketi

Proverava broj instaliranih paketa na sistemu. Podržava proveru za dpkg i rpm package manager-e.

Bezbednosni problemi:

- Svaki nepotrebno instalirani paket može da predstavlja sigurnosni rizik. Preporučuje se da se broj instaliranih paketa smanji na neophodan minimum. U slučaju veb servera, paketi poput grafičkog interfejsa i igri ne trebaju biti instalirani.

Mreža i firewall

Otvoreni portovi i servisi

Prikazuje sve TCP i UDP portove na kojima sistem sluša. Za svaki TCP port proverava da li je servis dostupan sa svih mrežnih interfejsa (0.0.0.0 ili ::) ili samo sa lokalnog interfejsa (127.0.0.1).

Bezbednosni problemi:

- Servisi koji slušaju na svim interfejsima povećavaju napadnu površinu sistema.
- Servisi koji treba da budu interno dostupni (npr. baze podataka), a slušaju na 0.0.0.0 direktno su izloženi spoljnim napadima.
- Neočekivano otvoreni portovi mogu ukazati na kompromitovanje sistema ili instalaciju neovlašćenih servisa.

Firewall pravila

Proverava IPv4 i IPv6 firewall pravila na sistemu. Analizira politiku INPUT china, prisutnos IP whiteliste za SSH port i da li se pravila automatski učitavaju pri svakom pokretanju sistema.

Bezbednosni problemi:

- ACCEPT politika na INPUT chainu znači da su sve dolazne konekcije dozvoljene.
- SSH bez IP whiteliste (port 22 otvoren za sve) čini server metom automatizovanih brute-force napada.
- Odsustvo IPv6 pravila omogućava napadaču da zaobiđe IPv4 firewall koristeći IPv6.
- Neperzistentna pravila ostavljaju sistem nezaštićen nakon svakog ponovnog pokretanja.

Napomena: Potreban je root pristup za čitanje pravila.

Mrežni interfejsi

Prikazuje sve aktivne mrežne interfejse i tabelu rutiranja. Proverava prisustvo potencijalno neočekivanih interfejsa kao što su tuneli i VPN konekcije (tun, tap, vpn, wg).

Bezbednosni problemi:

- Neočekivani tunelski interfejsi (tun/tap/WireGuard) mogu ukazati na neovlašćenu VPN konekciju ili kompromitovanje sistema.
- Uvid u tabelu rutiranja otkriva da li saobraćaj prolazi kroz neočekivane putanje, što može biti znak mrežnog napada (npr. man-in-the-middle).
- Prisustvo više mrežnih interfejsa na serveru koji bi trebalo da ima samo jedan može ukazati na lateralno kretanje napadača unutar mreže.

SSH konfiguracija

Analizira konfiguracioni fajl SSH servisa.

Parametar	Rizik ako nije ispravno podešen
PermitRootLogin	Direktan root pristup sistemu bez potrebe za eskalacijom privilegija
Protocol	SSH v1 sadrži poznate kriptografske slabosti i ranjivosti
AllowTcpForwarding	Korisnici mogu tunelirati saobraćaj i zaobići mrežna ograničenja
Port	Standardni port 22 je meta svih automatizovanih SSH skenera i brute-force alata
PasswordAuthentication	Lozinke su podložne brute-force napadima; SSH ključevi su znatno bezbedniji
MaxAuthTries	Visok broj dozvoljenih pokušaja prijave olakšava brute-force napade

Tabela 1 - SSH bezbednosni problemi

DNS konfiguracija

Proverava konfigurisane DNS servere, nestandardne unose u /etc/hosts fajlu i konfiguraciju nsswitch.conf fajla koji definiše redosled razrešavanja korisnika, grupa i hostnamova na sistemu.

Bezbednosni problemi:

- Nepouzdana eksterni DNS serveri mogu biti vektori DNS hijacking napada. Napadač može preusmeriti saobraćaj na maliciozne servere.
- Unosi u /etc/hosts mogu biti backdoor mehanizam koji preusmerava legitimne domene na napadačeve servere, bez potrebe za kompromitovanje DNS-a.
- LDAP/NIS konfiguracija u nsswitch.conf proširuje upravljanje korisnicima na mrežni nivo. Pogrešna konfiguracija može dozvoliti neovlašćenim korisnicima pristup sistemu.

Fajl sistem i servisi

Setuid fajlovi

Pretražuje fajl sistem i pronalazi sve fajlove sa setuid bitom (find / -perm -4000). Za svaki pronađeni fajl prikazuje putanju i vlasnika, a root-owned fajlove posebno označava. Bezbjednosni problemi:

- Setuid fajlovi se izvršavaju sa privilegijama vlasnika, a ne korisnika koji ih je pokrenuo. Ako je vlasnik root, napadač koji pronađe ranjivost u takvom binarnom fajlu može direktno eskalirati privilegije.
- Neočekivani setuid fajlovi van standardnih sistemskih lokacija mogu ukazati na kompromitovanje sistema.

Fajlovi koje svi korisnici mogu da mijenjaju

Pronalazi sve fajlove koje bilo koji korisnik može mijenjati (find / -type f -perm -002), uključujući /proc i /sys. Bezbjednosni problemi:

- Napadač koji dobije pristup sistemu može izmjeniti world-writable fajlove koje pokreće privilegovani korisnik ili servis, što može dovesti do eksalacije privilegija ili izvršavanja malicioznog koda.
- Konfiguracioni fajlovi i skripte koje može bilo ko mijenjati su direktna meta za ubacivanje zlonamjernog sadržaja

Backup fajlovi sa lošim permisijama

Provjerava poznate backup direktorijume (/backup, /var/backups, ..) i pretražuje file system sa ekstenzijama .bak, .old, .backup i shadow.backup. Bezbjednosni problemi:

- Backup fajlovi često sadrže kopije osjetljivih podataka kao što su keševi lozinki (/etc/shadow), privatni ključevi ili konfiguracije sa lozinkama.
- Administratori često zaborave da podese ispravne permisije na backup fajlovima, čineći ih čitljivim svim korisnicima

Crontab zadaci i permisije skripti

Pregleda sistemske cron taskove (/etc/crontab, /etc/cron.d/) i per-user crontabove. Za svaku skriptu koja se poziva provjerava da li je world-writable. Bezbjednosni problemi:

- Ako skripta koju pokreće root cron task ima loše postavljene permisije, bilo koji korisnik može izmjeniti i pri sljedećem pokretanju izvršiti proizvoljni kod sa root privilegijama.
- Cron taskovi koji se tako izvršavaju između 2h i 3h ujutru mogu biti pokrenuti 0 ili 2 puta tokom prelaska na ljetnje računanje vremena, što može dovesti do nekonzistentnog stanja sistema.

Mounted particije

Čita `/etc/fstab` i za svaku particiju provjerava mount opcije, sa posebnim fokusom na `/tmp`, `/home`, `/var` i `/dev`. Bezbjednosni problemi:

- Odsustvo `noexec` opcije na `/tmp` ili `/home` omogućava korisnicima da postave i izvrše binarne fajlove sa tih particija, što je česta tehnika u eskalaciji privilegija.
- Odsustvo `nosuid` sprečava interpretaciju `setuid` nita na particijama korisničkim podacima.
- Koršćenje `noatime` onemogućava zabilježavanje vremena posljednjeg pristupa fajlu, što otežava forenzičku analizu u slučaju upada u sistem.